

How to Check Regulatory Compliance in Wazuh: PCI DSS, GDPR, NIST & HIPAA

Regulatory compliance means we are following the rules and standards of a specific industry like PCI DSS, HIPAA, GDPR, NIST 800-53 etc.



WAZU helps us technically monitor these rules and informs us to what extent our system is complying with these rules and standards.

Compliance Standards and Vulnerability Detection

PCI DSS compliance ensures that internal vulnerability scans are run. WAZUH helps us in fulfilling this requirement, especially requirement 11.2, and this rule or compliance is designed for the credit card industry (Payment Card, Industry Data, Security Standard)

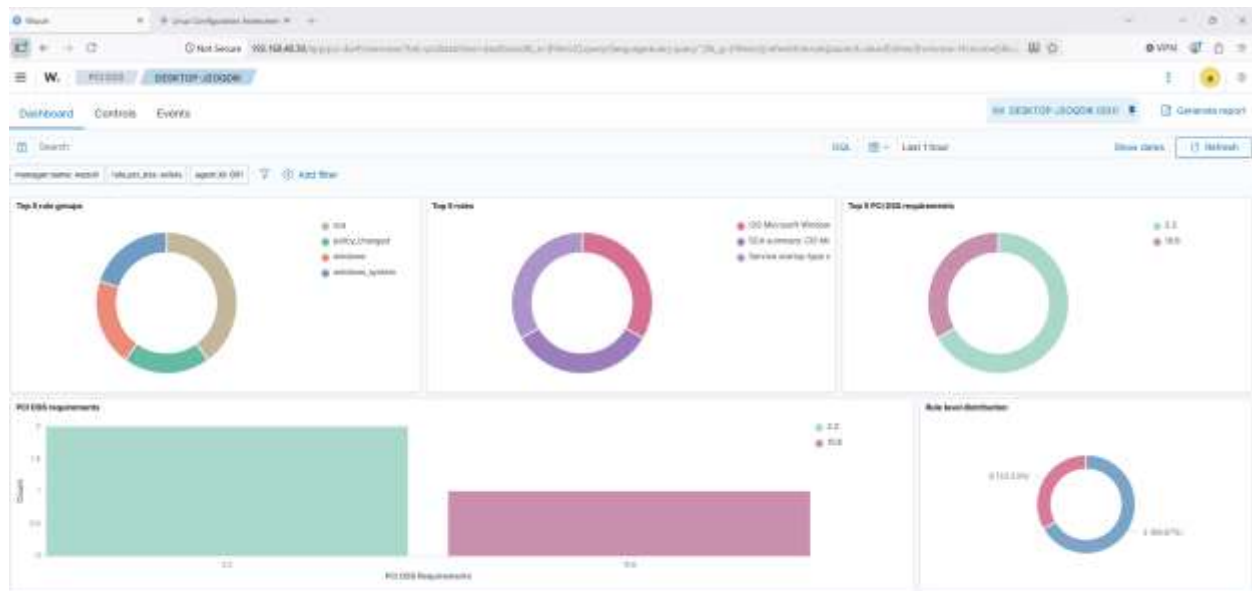
GDPR compliance requires technical measures to ensure security. Its primary purpose is to patch known bugs

NIST 800-53 compliance requires scanning for vulnerabilities in the system

HIPAA compliance requires protection against malicious software or security flaws and specifically ensures the privacy and security of patient health information

Focus on PCI DSS

Click on PCI DSS.



This dashboard basically tells us which PCI DSS rules the activities on our Windows agent, matched with over the last hour.

Here we have bar charts and a donut chart being shown.

Let me explain them.

- **Top 5 Rule Groups (Donut Chart):** Breaks down activity by functional groups, highlighting categories such as security configuration assessment (sca), file integrity or policy changes (policy_changed), and Windows system events.
- **Top 5 Rules (Donut Chart):** Shows the most frequently triggered specific rules on the agent, including CIS Microsoft Windows benchmark checks and service startup type modifications.

Top 5 PCI DSS Requirements & Requirements Bar Chart: Highlights the exact PCI DSS sub-requirements mapped to recent agent events

Requirement 2.2 color is green count is 2. Requirement 2.2 means configuration hardening. This is the highest one. This means WAZUH checked that some settings on our Windows machine are default or not secure. For example, the password policy is weak or unnecessary services are running.

Requirement 10.6 color is red and count is 1, which means log review. Meaning we should review logs daily. Whenever WAZUH collects logs or detects a file change, this requirement is triggered.

Now what is the essence?

This dashboard isn't just showing data but telling us that WAZUH has successfully checked our system according to PCI DSS standards and informed us which requirements our system is not fulfilling and what things we need to improve.

- **Rule Level Distribution (Donut Chart):** Displays the severity breakdown of the triggered events, showing that 66.67% (3 events) fall under one rule severity level while 33.33% (9 events — noting total aggregate volume) fall under another, helping security analysts prioritize critical alerts.